# Lab 08 — Threat Actors & the MITRE ATT&CK Framework

> **SY0-701 Objective 2.1** — Compare and contrast common threat actors and motivations
>
> **Domain 2** — Threats, Vulnerabilities, and Mitigations (22%) · **Time:** ~20 min · **Course:** TGS-2023039181 CompTIA Security+ (SY0-701)

**Goal:** profile a real advanced persistent threat (APT) group from authoritative data and classify its actor type, motivation and techniques.

**You'll build:** a JSON-driven threat-actor profile that ties one named APT group to its MITRE ATT&CK techniques.

**Prerequisites:** Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; internet access to download the dataset; tools installed in step 1.

## Background

- A **threat actor** is any entity able to cause a security event; the exam names nation-state, organized crime, hacktivist, insider threat, unskilled attacker and shadow IT.
- Actors are told apart by **attributes**: internal vs external, resources/funding, and level of sophistication/capability.
- Each actor pairs with **motivations** such as financial gain, espionage, data exfiltration, service disruption, blackmail, ideology, revenge or chaos.
- **MITRE ATT&CK** is a public knowledge base of real-world adversary tactics and techniques, grouped into *intrusion sets* (threat groups) you can query programmatically.
- Mapping an actor to its ATT&CK techniques turns "who might attack us" into a concrete, testable threat model.

## Steps

### 1. Install the tools

Install `jq` (a JSON processor) and `curl` to fetch and query the dataset.

```
apt-get update -qq && apt-get install -y jq curl
```

### 2. Download the ATT&CK Enterprise dataset

MITRE publishes the whole Enterprise matrix as a single STIX JSON file in its public CTI repository.

```
curl -sLo attack.json https://raw.githubusercontent.com/mitre/cti/master/enterprise-attack/enterprise-attack.json
ls -lh attack.json
```

### 3. Confirm the dataset loaded

Count the objects to prove the file parsed as valid JSON.

```
jq '.objects | length' attack.json
```

```
Expect a large number (tens of thousands of objects).
```

### 4. List the intrusion sets (threat groups)

Each named adversary group is an object of type `intrusion-set`.

```
jq -r '.objects[] | select(.type=="intrusion-set") | .name' attack.json | sort | head -20
```

### 5. Profile one group's aliases and description

Pick a well-documented group. APT29 (a nation-state espionage actor) is a good example.

```
jq -r '.objects[] | select(.type=="intrusion-set" and .name=="APT29") | {name, aliases,
description}' attack.json
```

### 6. Extract the techniques attributed to the group

Each group links to `attack-pattern` objects (techniques) through relationships. List technique names and their ATT&CK IDs.

```
jq -r '.objects[] | select(.type=="attack-pattern") | [( .external_references[]? |
select(.source_name=="mitre-attack") | .external_id), .name] | @tsv' attack.json | sort -u
| head -20
```

### 7. Classify the actor type and motivation

This is a thinking step — no command. Using the group's description, decide: - **Actor type:** is this a nation-state, organized crime, hacktivist, insider or unskilled attacker? - **Attributes:** internal/external, resources/funding, sophistication. - **Motivation:** espionage, financial gain, service disruption, ideology, revenge?

APT29's description points to state sponsorship and intelligence collection, so: nation-state actor, external, high resources and sophistication, motivation = espionage.

### 8. Record the profile as a threat note

Capture the conclusion in a reusable note alongside three ATT&CK technique IDs you found.

```
cat > profile.txt <<'EOF'
Threat-actor profile
Group:        APT29 (Cozy Bear)
Actor type:   Nation-state
Attributes:   External, high resources/funding, high sophistication
Motivation:   Espionage / data exfiltration
Techniques:   T1566 Phishing, T1059 Command and Scripting, T1071 App Layer Protocol
```

```
EOF
cat profile.txt
```

## Test it

Confirm the profile exists and names the actor type, motivation and at least three techniques.

```
test -s profile.txt && grep -Eiq 'nation-state' profile.txt && grep -Eiq
'espionage|exfiltration' profile.txt && grep -Ec 'T[0-9]{4}' profile.txt && echo "PROFILE
OK"
```

Expected: the technique count prints `3` (or more) followed by `PROFILE OK`.

## Troubleshooting

| Symptom | Fix |
|---|---|
| `curl` returns an empty file | The raw URL may have moved; try `https://github.com/mitre/cti` and browse to `enterprise-attack/enterprise-attack.json`. |
| `jq: error` on parse | The download was truncated; re-run step 2, then re-check with `jq '.objects \| length'`. |
| Group name not found | Names are case-sensitive; list them with step 4 and copy one exactly, e.g. `"APT28"`. |

## Challenge

Profile a second group with a different motivation (for example a hacktivist or an organized-crime group), then list the ATT&CK technique IDs the two groups have in common.

## Reflection

Objective 2.1 asks you to compare actors and motivations. How does knowing a group's *motivation* change which of your assets you would expect it to target first?

## Exam tips

- Nation-state = most resources and sophistication; organized crime = most financially motivated.
- Unskilled attacker (formerly script kiddie) has low skill but can still cause high impact with borrowed tools.
- Shadow IT is unsanctioned and risky but usually **not** malicious.
- An APT describes a long-term, well-funded *campaign* (usually nation-state), not a single piece of malware.

## References

- MITRE ATT&CK — https://attack.mitre.org
- MITRE ATT&CK Groups — https://attack.mitre.org/groups/
- MITRE CTI (STIX data) — https://github.com/mitre/cti
- NIST SP 800-150 Cyber Threat Information Sharing — https://csrc.nist.gov/pubs/sp/800/150/final